



Phishing Attack

Date: 12nd July

Tester: Duyghu Asgarova

Table of Contents

Executive Summary.....	3
Objectives.....	3
Attack Methodology.....	3
Domain Infrastructure.....	3
Phishing Framework.....	3
Email Details.....	4
Email Delivery Setup.....	4
Visual Evidences.....	4
Key Observations.....	12
Risk Assesment.....	13
Conclusion.....	14
Confidentiality Statement.....	14

Executive Summary

This report presents a controlled phishing simulation executed by the Red Team to evaluate the organization's user awareness and technical defenses against phishing attacks. The simulation mimicked a legitimate academic portal ("Student Cabinet") using a custom domain (kabinetunec.online) registered through GoDaddy, with the infrastructure hosted using GoPhish and Cloudflare Tunnel for secure HTTPS delivery.

The attack aimed to test how many users would:

- Open and interact with suspicious-looking emails,
- Click on links embedded within those emails, and
- Submit sensitive information (credentials) via a deceptive login form.

Results revealed a high click-through and submission rate, highlighting areas of vulnerability in both user behavior and technical controls.

Objectives

The goals of the phishing engagement were:

- Evaluate user susceptibility to social engineering and realistic phishing tactics
- Test the effectiveness of spam/email filters across the institution's mail systems
- Measure behavior when faced with a time-sensitive academic login request
- Identify gaps in security training and technical safeguards
- Provide data-driven recommendations to reduce phishing risks

Attack Methodology

Domain Infrastructure

- A realistic domain, kabinetunec.online, was purchased via GoDaddy.
- The domain's purpose was to impersonate a student portal login ("Cabinet Unec").
- DNS settings were pointed to a Cloudflare Tunnel which securely forwarded traffic to the phishing server hosted locally.

Phishing Framework

- **Tool Used:** [GoPhish](#)
- **Server Environment:** macOS, listening on port 5000
- **Secure Tunnel:** Cloudflare Tunnel with HTTPS
- **Landing Page:** A custom HTML page mimicking a legitimate "cabinet" login system used by students.

Email Details

- **Sender:** kabinetunec@gmail.com
- **Subject:** "Urgent: Confirm Access to Your Student Cabinet"
- **Message Content:**
 - Notified students about academic cabinet access renewal.
 - Included a clickable button ("Access Your Cabinet Now").
 - Created urgency by stating the cabinet would be locked within 24 hours.

Email Delivery Setup

- **SMTP Provider:** Gmail
- **Authentication:** Gmail App Password
- **TLS Encryption:** Enabled
- Emails successfully bypassed spam filters and landed in primary inboxes for most targets.

Visual Evidences

```
duyguu16@Duygu-MacBook-Air gophish % ./gophish
time="2025-07-12T18:01:17+04:00" level=warning msg="No contact address has been configured."
time="2025-07-12T18:01:17+04:00" level=warning msg="Please consider adding a contact_address entry in your config.json"
goose: no migrations to run. current version: 20220321133237
time="2025-07-12T18:01:17+04:00" level=info msg="Starting admin server at https://127.0.0.1:3333"
time="2025-07-12T18:01:17+04:00" level=info msg="Starting phishing server at http://0.0.0.0:8080"
time="2025-07-12T18:01:17+04:00" level=info msg="Starting IMAP monitor manager"
time="2025-07-12T18:01:17+04:00" level=info msg="Background Worker Started Successfully - Waiting for Campaigns"
time="2025-07-12T18:01:17+04:00" level=info msg="Starting new IMAP monitor for user admin"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:36 +0400] \"GET /campaigns/6 HTTP/2.0\" 307 64 \"https://127.0.0.1:3333/campaigns/\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:36 +0400] \"GET /login?next=/2Fcampaigns%2F6 HTTP/2.0\" 200 1035 \"https://127.0.0.1:3333/campaigns/\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:36 +0400] \"GET /images/logo_inv_small.png HTTP/2.0\" 200 1118 \"https://127.0.0.1:3333/login?next=/2Fcampaigns%2F6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:36 +0400] \"GET /images/logo_purple.png HTTP/2.0\" 200 4735 \"https://127.0.0.1:3333/login?next=/2Fcampaigns%2F6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:36 +0400] \"POST /login?next=/2Fcampaigns%2F6 HTTP/2.0\" 200 52514 \"https://127.0.0.1:3333/login?next=/2Fcampaigns%2F6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:36 +0400] \"GET /js/dist/vendor.min.js HTTP/2.0\" 200 324943 \"https://127.0.0.1:3333/login?next=/2Fcampaigns%2F6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:36+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:39 +0400] \"GET /images/logo_inv_small.png HTTP/2.0\" 200 1118 \"https://127.0.0.1:3333/campaigns/6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:39+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:39 +0400] \"GET /js/dist/app/gophish.min.js HTTP/2.0\" 200 1107 \"https://127.0.0.1:3333/campaigns/6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:39+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:39 +0400] \"GET /font/fontawesome-webfont.woff2?v=4.7.0 HTTP/2.0\" 200 77177 \"https://127.0.0.1:3333/login?next=/2Fcampaigns%2F6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:39+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:39 +0400] \"GET /js/dist/vendor.min.js HTTP/2.0\" 200 324943 \"https://127.0.0.1:3333/campaigns/6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
time="2025-07-12T18:01:39+04:00" level=info msg="127.0.0.1 - [12/Jul/2025:18:01:39 +0400] \"GET /api/campaigns/6/results?{} HTTP/2.0\" 200 823 \"https://127.0.0.1:3333/campaigns/6\" Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.1.1 Safari/605.1.15\"
```

First,I install gophish tool.

```
duyguu16@Duygu-MacBook-Air gophish % cloudflared tunnel run gophish-tunnel
2025-07-12T08:34:40Z INF Starting tunnel tunnelID=fd76cd88-ff5c-4042-9083-9c138a286d88
2025-07-12T08:34:40Z INF Version 2025.7.0 (Checksum 2338d4685adb66185d44ca1d9cc338be8e6e9ec978d59517ce47fd9658955d)
2025-07-12T08:34:40Z INF GOOS: darwin, GOVersion: go1.24.4, GoArch: arm64
2025-07-12T08:34:40Z INF Settings: map[cred-file:/Users/duyguu16/.cloudflared/fd76cd88-ff5c-4042-9083-9c138a286d88.json credentials-file:/Users/duyguu16/.cloudflared/fd76cd88-ff5c-4042-9083-9c138a286d88.json]
2025-07-12T08:34:40Z INF cloudflared will not automatically update if installed by a package manager.
2025-07-12T08:34:40Z INF Created ICMP proxy listening on 192.168.1.111:0
2025-07-12T08:34:40Z INF Initial protocol quic
2025-07-12T08:34:40Z INF ICMP proxy will use 192.168.1.111 as source for IPv4
2025-07-12T08:34:40Z INF ICMP proxy will use fe80::1456:608a:b0ef:da75 in zone en0 as source for IPv6
2025-07-12T08:34:40Z INF ICMP proxy will use 192.168.1.111 as source for IPv4
2025-07-12T08:34:40Z INF ICMP proxy will use fe80::1456:608a:b0ef:da75 in zone en0 as source for IPv6
2025-07-12T08:34:40Z INF Starting metrics server on 127.0.0.1:28241/metrics
2025-07-12T08:34:40Z INF Tunnel connection curve preferences: [X25519MLKEM768 CurveP256] connIndex=0 event=0 ip=198.41.192.73
2025-07-12T08:34:40Z INF Registered tunnel connection connIndex=0 connection=4d2f8cd8-8986-42b9-ad4a-d8b1e4b5164 event=0 ip=198.41.192.73 location=ams19 protocol=quic
2025-07-12T08:34:40Z INF Tunnel connection curve preferences: [X25519MLKEM768 CurveP256] connIndex=1 event=0 ip=198.41.192.167
2025-07-12T08:34:41Z INF Registered tunnel connection connIndex=1 connection=644a3e62-76a4-48d0-a0fe-aba8e8b7b001 event=0 ip=198.41.192.167 location=ams15 protocol=quic
2025-07-12T08:34:41Z INF Tunnel connection curve preferences: [X25519MLKEM768 CurveP256] connIndex=2 event=0 ip=198.41.192.7
2025-07-12T08:34:42Z INF Registered tunnel connection connIndex=2 connection=e0898d46-7b19-4d5a-babb-fa2ced214a79 event=0 ip=198.41.192.7 location=ams13 protocol=quic
2025-07-12T08:34:42Z INF Tunnel connection curve preferences: [X25519MLKEM768 CurveP256] connIndex=3 event=0 ip=198.41.192.43
```

After getting registered,I create a tunnel between cloudflare and gophish.

Code Academy/Duyghu Asgarova

Kabinet Unec

- Dashboard
- Domain
- Website
- Email
- Store
- Appointments
- Marketing
- Conversations 1
- Customers
- Deals

kabinetunec.online

Connect Domain

ⓘ Add Organization Name

Missing an organization name in your domain contact info? If you're managing for an organization, adding its name can assert domain ownership and aid in disputes. Make sure it matches official documents for easy recovery. Ready to add it?

[Add an organization](#)

Overview DNS Registration Settings Products

DNS Records Forwarding **Nameservers** Hostnames DS Records

Nameservers determine where your DNS is hosted and where you add, edit or delete your DNS records.

Using custom nameservers

Change Nameservers

Nameservers ⓘ

audrey.ns.cloudflare.com
coen.ns.cloudflare.com

Then I change settings of my domain kabinetunec.online, which I bought from GoDaddy. I changed Nameservers to ones in CloudFlare.

Esgerovaduygu2006@gmail.com's Account

Go to... Support + Add English

Account Home

Discover

Domain Registration

Log Explorer

Analytics & Logs

Security Center

Trace Beta

WAF

Turnstile

Load Balancing

IP Addresses

Zero Trust

Compute (Workers)

Secrets Store New

Workers for Platforms

Collapse sidebar

Price Reduction: Stream & Images Starter Bundle Now \$5/Month. [Get Started](#)

Account Home

Esgerovaduygu2006@gmail.com's account :

Domains Developer Platform Zero Trust New

+ Add a domain

Search by domain name... Search

Filter by: ☆ Starred

Domain	Status ⓘ	Security insights ⓘ	Unique visitors ⓘ	Plan
kabinetunec.online	✓ Active	Enable	17	Free

1 - 1 of 1 items

[Give feedback](#)

Support | System Status | Careers | Terms of Use | Report Security Issues | Privacy Policy [Cookie Preferences](#) © 2025 Cloudflare, Inc.

After 1 hour, my domain got activated on CloudFlare.

Esgerovaduygu2006@gmail.com's Account

Go to...
Support
+ Add
English

kabinetunec.online

Active

Star

Free plan

Overview

AI Audit Beta

Log Explorer

Analytics & Logs

DNS

Records

Analytics

Settings

Email

SSL/TLS

Security

Access

Speed

Caching

Workers Routes

Rules

Add filter

Search

Add record

☐	Type ①	Name ①	Content ①	Proxy status ①	TTL ①	Actions
☐	A	kabinetunec.online	51.21.152.144	Proxied	Auto	Edit
☐	CNAME	_domainconnect	_domainconnect.gd.d...	Proxied	Auto	Edit
☐	CNAME	edu	fd76cd88-ff5c-4042-...	Proxied	Auto	Edit
☐	NS	kabinetunec.online	ns08.domaincontrol.c...	DNS only	Auto	Edit
☐	NS	kabinetunec.online	ns07.domaincontrol.c...	DNS only	Auto	Edit
☐	TXT	_dmarc	"v=DMARC1; p=reject;...	DNS only	Auto	Edit

Cloudflare Nameservers

Every DNS zone on Cloudflare is assigned a set of Cloudflare-branded nameservers.

Type	Value
NS	audrey.ns.cloudflare.com
NS	coen.ns.cloudflare.com

Chat

I add cname record with content of tunnel key. My domain is automatically served over SSL/TLS (HTTPS).

App pas

App passwords help services that don't

App passwords are that use modern se you should check to

[Learn more](#)

Your app passw

unec

To create a new a

App name

Generated app password

Your app password for your device

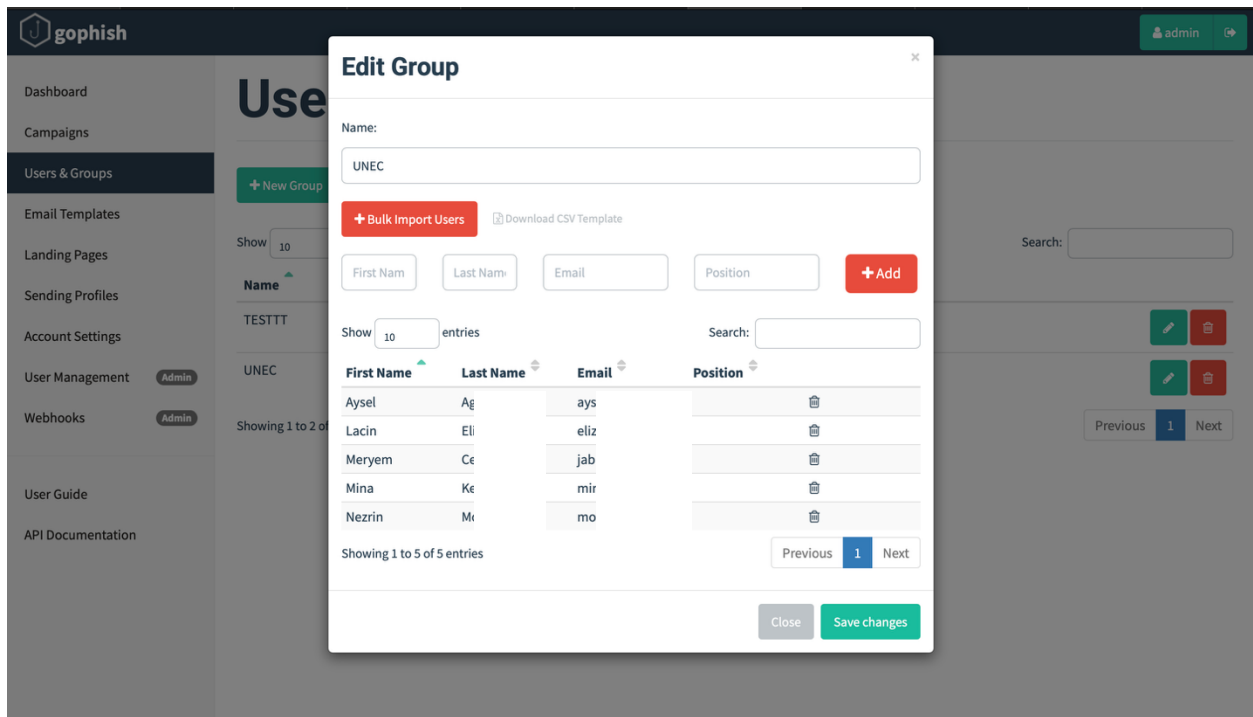
How to use it

Go to the settings for your Google Account in the application or device you are trying to set up. Replace your password with the 16-character password shown above.

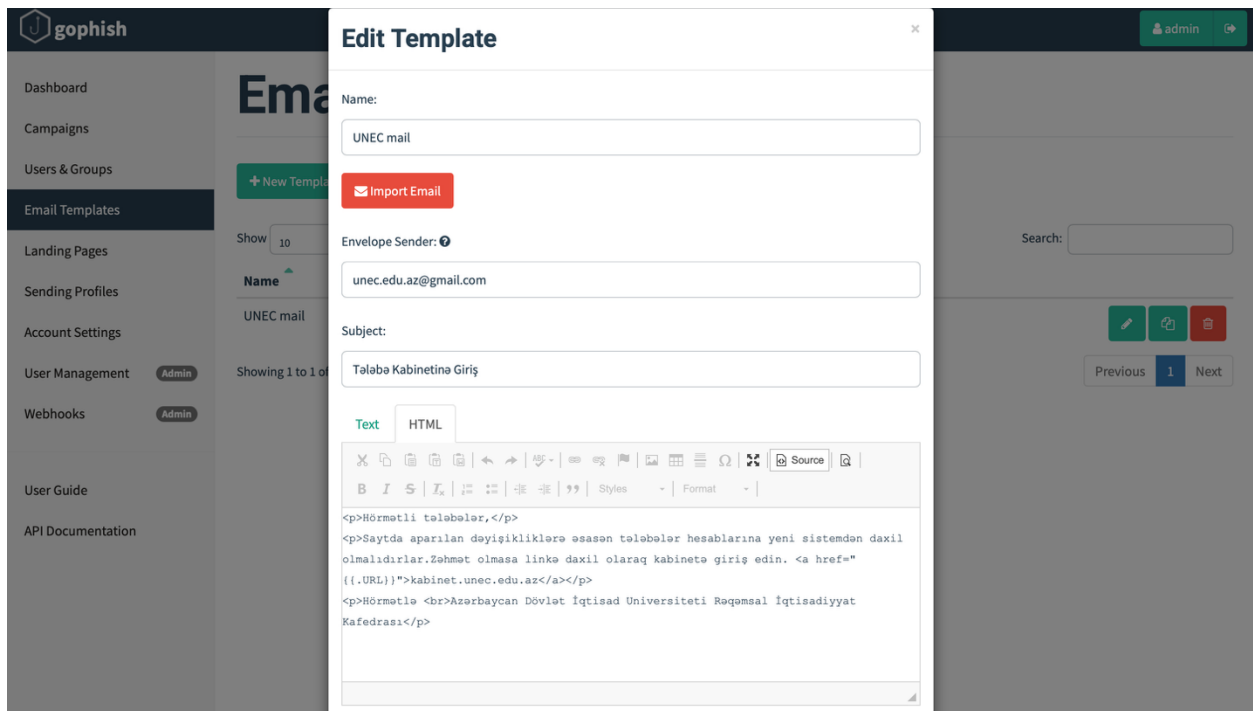
Just like your normal password, this app password grants complete access to your Google Account. You won't need to remember it, so don't write it down or share it with anyone.

Done

I also generated app password for future use.

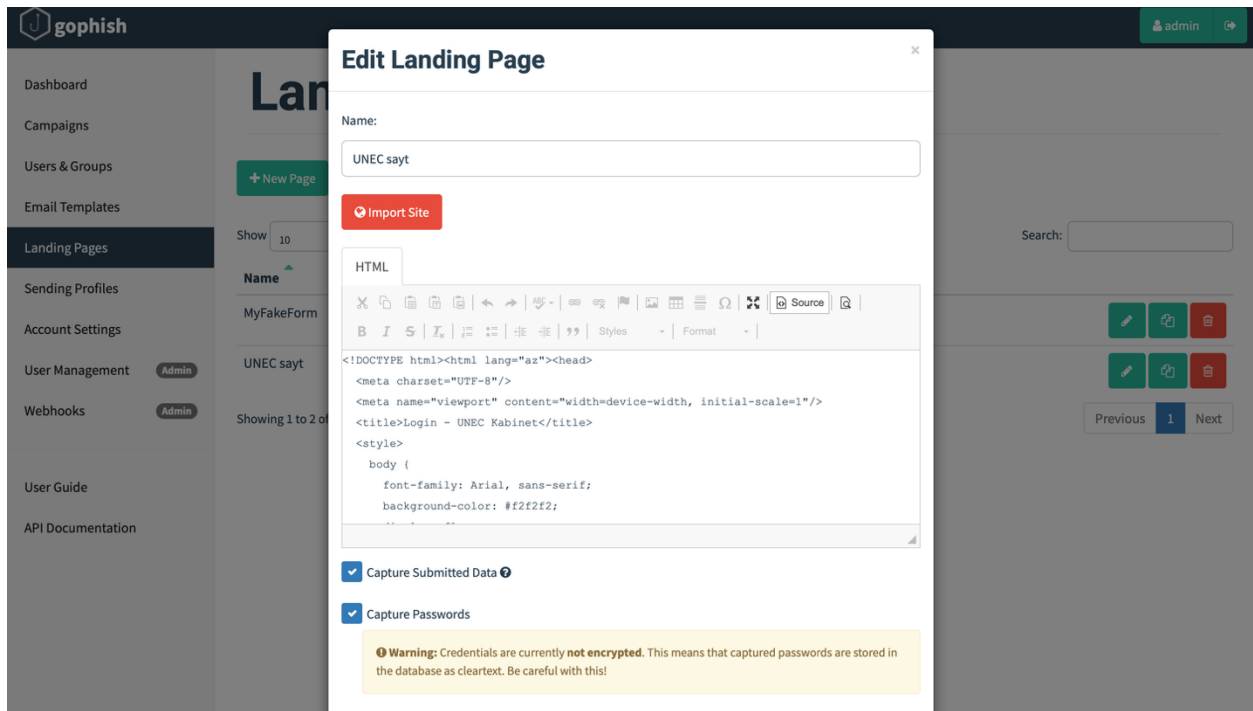


I create a group which is consists of my groupmates.

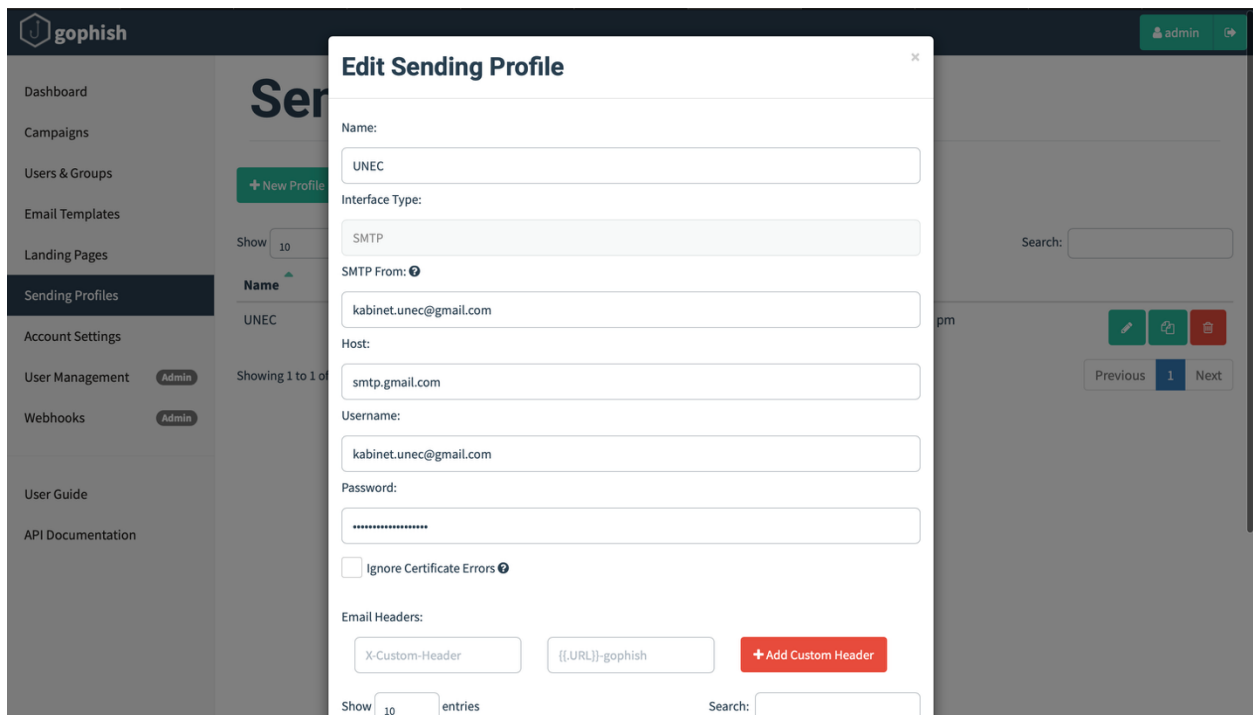


I made an email template.

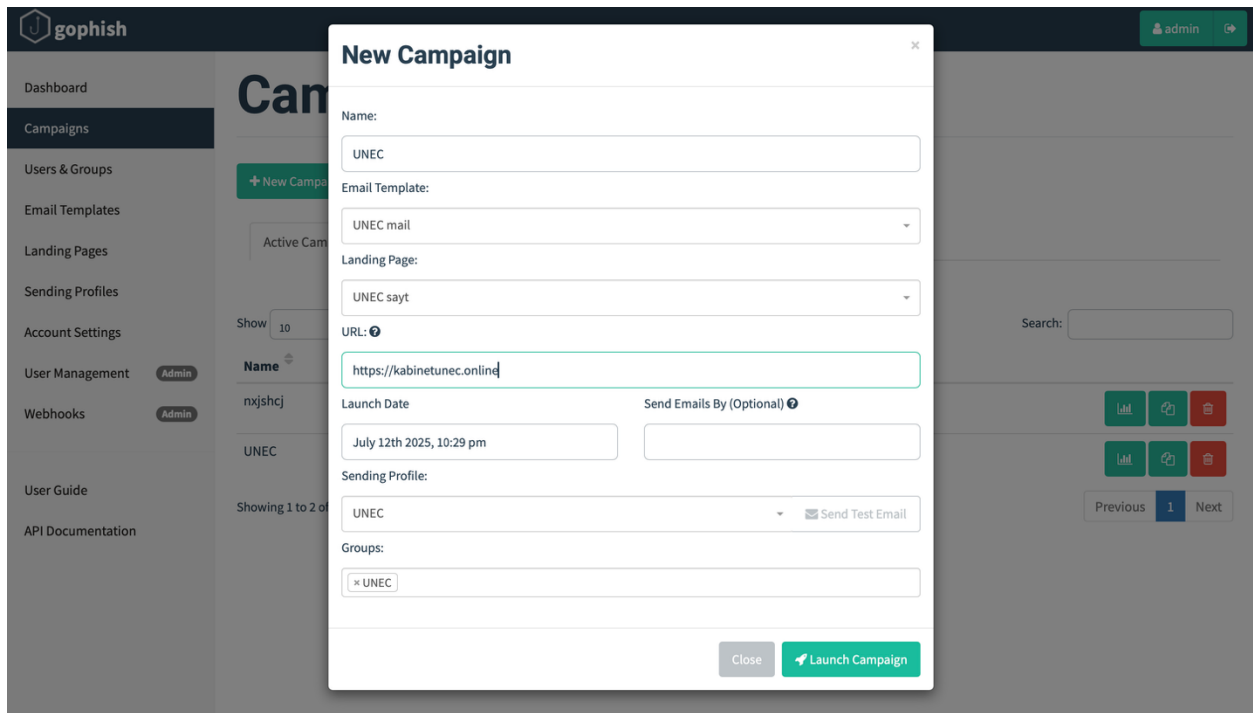
Code Academy/Duyghu Asgarova



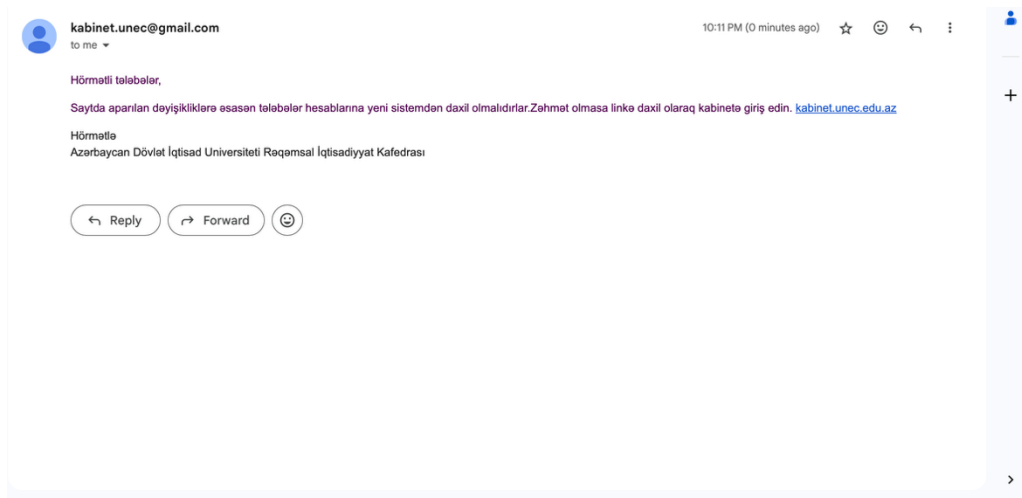
I created a landing page.

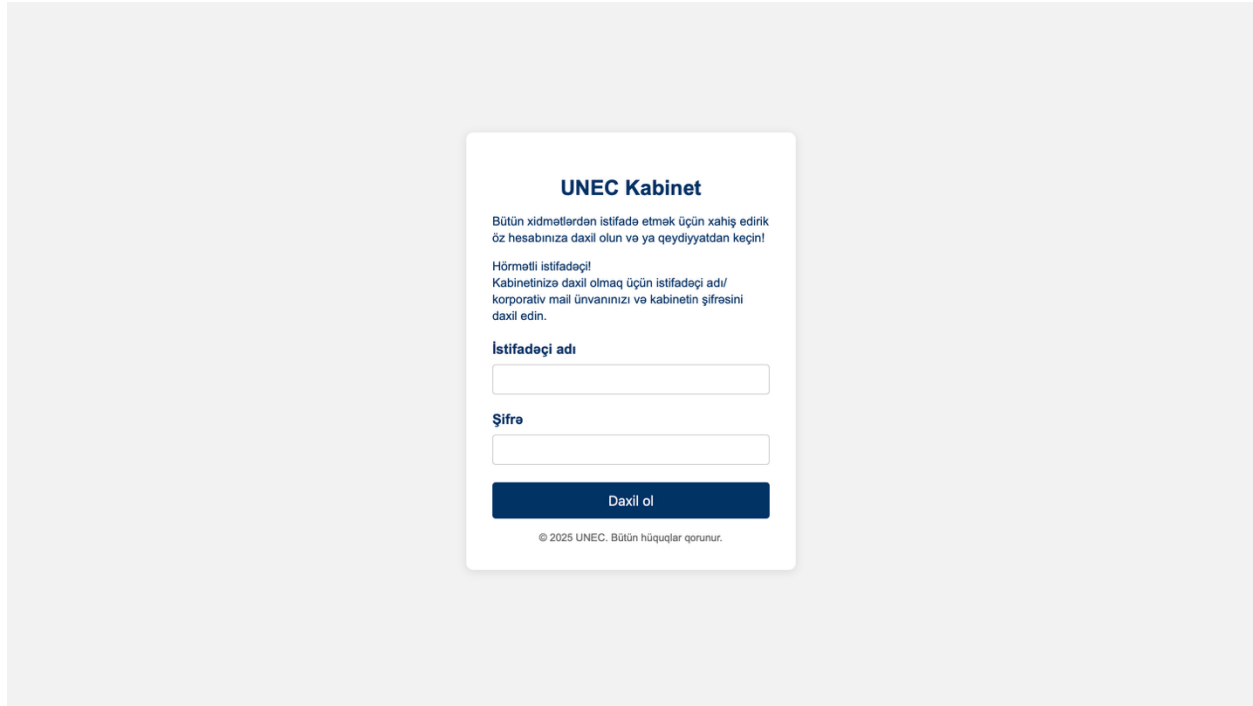


I made my sending profile, paste password which is my gmail app password.

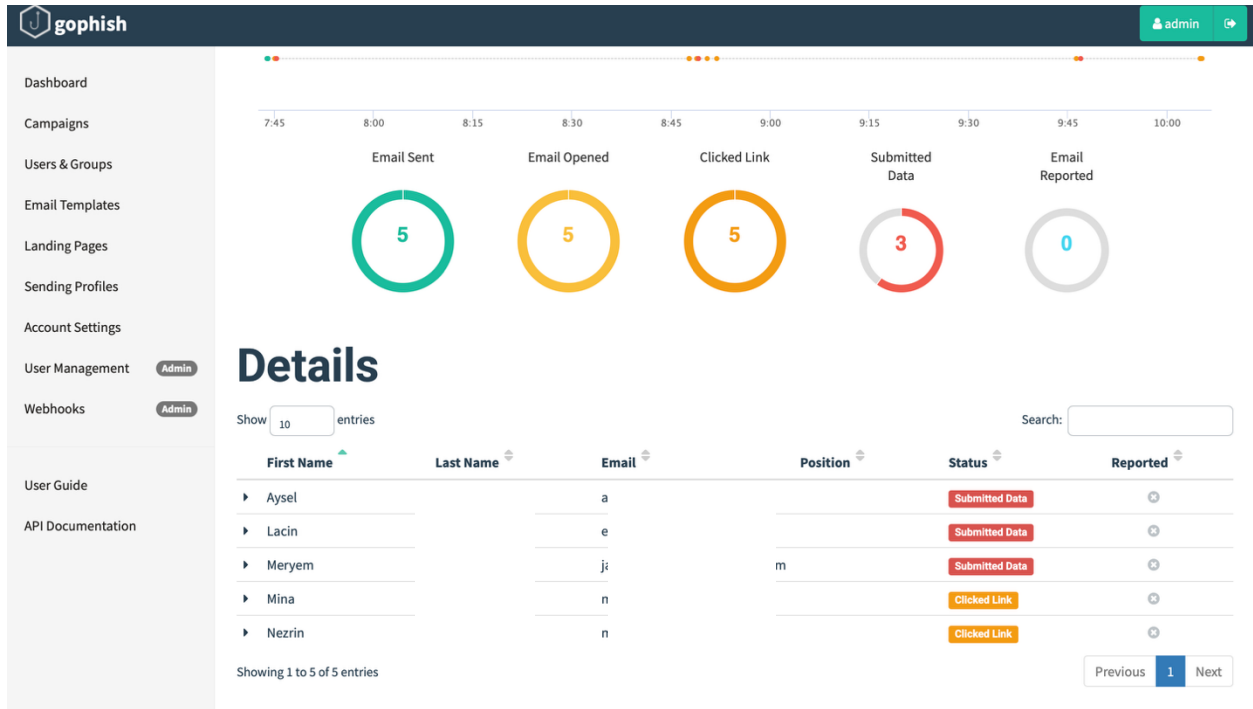


I launched a new campaign.





This is how phishing looks like.



admin

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Account Settings

User Management Admin

Webhooks Admin

User Guide

API Documentation

First Name

Last Name

Email

Position

Status

Reported

Aysel

Submitted Data

Timeline for Aysel

Email: ays

Result ID:

Campaign Created

July 12th 2025 7:43:56 pm

Email Sent

July 12th 2025 7:43:57 pm

Clicked Link

July 12th 2025 9:46:17 pm

Android (OS Version: 10)

Chrome (Version: 136.0.0.0)

Submitted Data

July 12th 2025 9:46:59 pm

Android (OS Version: 10)

Chrome (Version: 136.0.0.0)

Replay Credentials

View Details

Parameter	Value(s)
password	Si
username	Si

admin

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Account Settings

User Management Admin

Webhooks Admin

User Guide

API Documentation

Email Sent

July 12th 2025 7:43:58 pm

Clicked Link

July 12th 2025 8:47:46 pm

Android (OS Version: 10)

Chrome (Version: 138.0.0.0)

Clicked Link

July 12th 2025 8:47:46 pm

Android (OS Version: 10)

Chrome (Version: 138.0.0.0)

Clicked Link

July 12th 2025 8:47:46 pm

Android (OS Version: 10)

Chrome (Version: 138.0.0.0)

Clicked Link

July 12th 2025 8:48:53 pm

Android (OS Version: 10)

Chrome (Version: 138.0.0.0)

Submitted Data

July 12th 2025 8:49:07 pm

Android (OS Version: 10)

Chrome (Version: 138.0.0.0)

Replay Credentials

View Details

Parameter	Value(s)
password	14
username	l.e

Code Academy/Duyghu Asgarova

11

admin

Dashboard
Campaigns
Users & Groups
Email Templates
Landing Pages
Sending Profiles
Account Settings
User Management Admin
Webhooks Admin
User Guide
API Documentation

Meryem
com
Submitted Data

Timeline for Meryem

Email: jal mail.
Result ID:

- Campaign Created July 12th 2025 7:43:56 pm
- Email Sent July 12th 2025 7:43:59 pm
- Clicked Link July 12th 2025 7:45:03 pm
 - Apple iPhone (OS Version: 16.3.1)
 - Safari (Version: 16.3)
- Submitted Data July 12th 2025 7:45:22 pm
 - Apple iPhone (OS Version: 16.3.1)
 - Safari (Version: 16.3)

Replay Credentials

View Details

Parameter	Value(s)
password	M
username	m

admin

Dashboard
Campaigns
Users & Groups
Email Templates
Landing Pages
Sending Profiles
Account Settings
User Management Admin
Webhooks Admin
User Guide
API Documentation

Replay Credentials
View Details

Mina
Clicked Link

Timeline for Mina I

Email: m
Result ID:

- Campaign Created July 12th 2025 7:43:56 pm
- Email Sent July 12th 2025 7:44:00 pm
- Clicked Link July 12th 2025 8:50:26 pm
 - Android (OS Version: 10)
 - Chrome (Version: 138.0.0.0)
- Clicked Link July 12th 2025 8:51:53 pm
 - Android (OS Version: 10)
 - Chrome (Version: 138.0.0.0)

These are results.

Key Observations

The use of the domain kabinetunec.online, combined with the academic context ("Student Cabinet Login"), made the phishing page appear legitimate. This likely contributed to the 3 victims trusting the page enough to enter their information.

Code Academy/Duyghu Asgarova

12

Of the 5 who clicked, 3 users (60%) submitted their credentials via the fake login page hosted at <https://kabinetunec.online>. This high submission-to-click ratio suggests that the landing page was convincing and did not raise suspicion among those who clicked. None of the recipients reported the phishing email to IT or security staff. This shows a lack of clear phishing reporting channels or training on what to do when suspicious messages are received.

The phishing email was delivered successfully to all recipients without being flagged or quarantined. This demonstrates potential weaknesses in the institution's email filtering or DMARC/SPF/DKIM enforcement.

Risk Assessment

Risk	Impact	Likelihood
Credential Theft	High	High
Unauthorized Access to Academic Systems	High	Medium
Loss of Trust in Email Systems	Medium	Medium
Compliance Violation	Medium	Low
Phishing Chain Reaction (peer sharing)	High	Medium

Recommendations

User Awareness

- Conduct targeted security awareness training focused on phishing and spoofed domains.
- Launch quarterly phishing simulations and track improvements.

Technical Controls

- Improve SPF, DKIM, and DMARC enforcement for both inbound and outbound mail.
- Introduce banners for emails received from external domains (e.g., "This message comes from outside your organization").
- Use anomaly detection tools to identify suspicious bulk links or logins.

Access & Authentication

- Enforce Multi-Factor Authentication (MFA) on all student and faculty systems.

Consider implementing phishing-resistant authentication such as FIDO2 tokens or passkeys.

Conclusion

This Red Team phishing exercise revealed several exploitable vulnerabilities in user behavior and technical email defenses. The use of a realistic, institution-themed domain (kabinetunec.online) significantly increased the campaign's effectiveness, resulting in a high rate of credential capture.

To mitigate future risks, the organization must invest in a combination of security training, technical controls, and email infrastructure hardening. Ongoing Red Team testing should continue to ensure continuous improvement in security posture.

Confidentiality Statement

This document contains sensitive information derived from a controlled cybersecurity test. It is intended solely for the internal use of its authorized security personnel. Any unauthorized distribution, disclosure, or reproduction of this report is strictly prohibited.



Last Page